Course Code: ITA1439 **Course Name: Ethical Hacking** **Slot: A**

CO1 – ASSIGNMENT_1

Nature of Assignment: Individual **Duration: 1 Week** **Total Marks: 50**

Student Name: Sathish R **Reg. No: 192324204**

CO1: Apply the foundational concepts of ethical hacking, including the types of hackers, ethical principles, legal frameworks, and the role of responsible disclosure in cybersecurity.

Assignment Title: Design and Develop a Complete Ethical-Hacking Engagement Framework for a University's Authorized Security-Assessment Programme.

Scenario - University Authorized Security-Assessment Programme

A university is establishing an Authorized Security-Assessment Programme to test the security of its student portal, learning-management system, email service and campus network before a major upgrade. The programme must cover approximately 20 systems and 50 staff initially, but the framework is expected to remain usable as the programme grows to the whole university and begins to include external, third-party assessors.

The management has not yet fixed how ethical-hacking engagements will be governed. Testing may be requested by different departments, carried out by internal staff or external testers, and may touch systems that hold personal data. The team is concerned that an unstructured approach may lead to unauthorized access, legal exposure, damage to live systems, unclear scope or uncoordinated disclosure of discovered vulnerabilities.

You have been appointed as the Ethical-Hacking Governance Team. Your responsibility is not merely to describe hacking tools. You must investigate the requirements, design a complete engagement framework, construct reusable components and documents, integrate the different parts, validate the design through a walkthrough and defend the final framework using evidence.

The final framework must clearly distinguish between what is authorized, what is legal, and what is appropriate for the university. The team is expected to make governance decisions independently and justify why the framework is suitable for the given scenario. No live exploitation is performed; all work stays at the design, documentation and isolated-lab level.

Design Challenge

Create and validate an integrated ethical-hacking engagement framework for the university programme. The framework must define how an engagement is authorized, how scope and rules of engagement are

set, how the relevant laws are respected, how different types of attackers are modelled, how discovered vulnerabilities are disclosed responsibly, and how an isolated lab is used where hands-on testing is required.

Your final design must be usable in practice and must demonstrate interaction among the selected components rather than treating each document or rule as an isolated example. Every major governance decision must be supported by evidence and a clear explanation of the trade-offs involved.

TASK 1 – Formulate the Enquiry and Framework Blueprint **4 Marks**

• Convert the scenario into a formal set of engagement-governance requirements. Identify the systems in scope, the stakeholders, the expected activities and the constraints.

• Create a framework blueprint showing how authorization, scope, legal compliance, threat modelling, lab testing and disclosure will cooperate in the proposed programme.

• Formulate at least four enquiry questions that your framework must answer, such as who authorizes a test, what is in scope, which laws apply and how findings are disclosed.

• Define at least five design criteria and use them as acceptance criteria for the final framework.

Evidence Expected

A requirements-to-governance blueprint, enquiry questions, design criteria and a clear rationale showing how the proposed framework addresses the scenario.

TASK 2 – Design a Hacker Threat Model and Classification **4 Marks**

• Design a classification of the types of hackers relevant to the university, such as white-hat, black-hat, grey-hat, script kiddie, hacktivist, insider and state-sponsored actors.

• Map each type to its motivation, typical capability and likely targets within the university.

• Establish clear criteria and naming so that an actor can be classified consistently.

• Demonstrate at least two alternative ways of classifying one borderline actor, then choose and justify the final classification.

Evidence Expected

A documented hacker threat model, classification criteria, a mapping table, rejected alternatives and a justified final classification.

TASK 3 – Create an Ethics and Code-of-Conduct Module **4 Marks**

• Define the ethical principles that govern an authorized engagement, such as written authorization, agreed scope, confidentiality, integrity, avoiding harm and honest reporting.

• Design rules or checks that help detect or prevent unethical actions during an engagement.

• Construct scenario cases containing acceptable, borderline and unacceptable actions and show how the code of conduct responds to each.

• Explain how the module preserves trust and keeps the engagement lawful and professional.

Evidence Expected

A reusable code-of-conduct module, decision rules, scenario test cases and evidence that the rules separate acceptable from unacceptable actions.

TASK 4 – Construct a Legal-Compliance Mapping **4 Marks**

• Map the engagement to the relevant provisions of the Information Technology Act, 2000 on unauthorized access and data, and compare them with an international law such as the Computer Fraud and Abuse Act.

• Build a table of offences, obligations and penalties related to unauthorized access and data protection.

• Connect each legal requirement to a specific control in the engagement framework.

• Decide and justify which legal requirements apply when a test touches systems that hold personal data.

Evidence Expected

A legal-compliance mapping, an offences-and-penalties table, the controls linked to each requirement and a justified conclusion on which laws apply.

TASK 5 – Create a Scope and Rules-of-Engagement Document **4 Marks**

• Design a scope and rules-of-engagement (RoE) document that defines in-scope and out-of-scope systems, testing windows, permitted and prohibited techniques and escalation paths.

• Create rules for recording and verifying the written authorization behind each engagement.

• Establish clear naming and boundaries so that an out-of-scope request can be detected.

• Construct at least one transformation of the RoE into a pre-engagement checklist.

Evidence Expected

A complete RoE document, authorization-verification rules, scope boundaries and a derived pre-engagement checklist.

TASK 6 – Build an Authorization and Disclosure Layer **5 Marks**

• Create an authorization workflow covering the request, approval, written sign-off and recording of each engagement.

• Design a responsible (coordinated) disclosure process with a reporting format, remediation window and timeline, and compare it with full disclosure and bug-bounty approaches.

• Develop operations for logging approvals and status updates and for deciding when disclosure may proceed.

• Create rules for choosing between coordinated and full disclosure for a given finding.

• Demonstrate that this layer interacts correctly with the rules-of-engagement and legal-compliance components.

Evidence Expected

An authorization workflow, a responsible-disclosure process, logging and decision operations, disclosure rules and evidence of interaction with the other components.

TASK 7 – Design an Isolated Ethical-Hacking Lab **5 Marks**

• Design a safe, isolated lab using a Kali Linux machine and one or more authorized target machines on a host-only network with reserved addresses such as 192.168.56.0/24.

• Specify the components, roles and connectivity of the lab and the steps used to record its configuration.

• Develop at least two operations, such as verifying connectivity between the machines and recording the lab setup.

• Construct a small comparison between a host-only and a NAT lab network and justify the chosen design.

• Explain how the lab keeps all testing authorized and contained within the isolated environment.

Evidence Expected

An isolated-lab design, a component and connectivity specification, verification operations, a comparison of network options and a justified final lab model.

TASK 8 – Develop a Reusable Document Library **5 Marks**

• Create a minimum of four reusable engagement documents supporting the framework, including at least one authorization form and one finding report.

• Use sensible default fields where appropriate and explicitly design the content of each document.

• At least one document, such as the finding report, must produce a structured output that integrates with another component of the framework.

• Create test entries that demonstrate valid, boundary and invalid inputs and document the expected result.

Evidence Expected

A reusable document library, documented fields, a structured report output, test entries and evidence of integration with the framework.

TASK 9 – Integrate, Test and Refine the Framework **5 Marks**

• Integrate the components created in Tasks 2-8 into one coherent engagement framework.

• Construct a realistic walkthrough of an authorized assessment from request and authorization, through testing in the isolated lab, to responsible disclosure.

• Design systematic test cases covering missing authorization, out-of-scope requests, legal conflicts and delayed disclosure.

• Record the problems encountered during the walkthrough and show how the framework was refined to address them.

Evidence Expected

A reproducible integrated framework, a workflow walkthrough, systematic test cases, refinement evidence and a final corrected framework.

TASK 10 – Create a Scalability and Governance Evaluation 5 Marks

• Construct scenarios representing a small programme (one department) and a large programme (the whole university with external assessors), with the number of systems and testers involved.

• Experiment with at least three important processes from the framework and record meaningful measures such as approval turnaround, scope coverage or the number of steps.

• Create a comparison table and at least one suitable chart or structured visualization.

• Use the evidence to refine the governance of the framework rather than simply reporting the measures.

Evidence Expected

A reproducible evaluation setup, a comparison table, a visualization, an interpretation and evidence of at least one governance refinement based on the results.

TASK 11 – Defend the Framework Under a Changed Requirement 5 Marks

• Changed requirement: the university now runs continuous and third-party assessments with stricter data-protection rules and a shorter disclosure timeline, and needs the framework to remain easy to govern and extend.

• Create a revised version of your framework by deciding which components should be retained, modified, replaced or redesigned.

• Construct at least one new or modified component that directly addresses the changed requirement and show how it integrates with the existing framework.

• Defend the final framework using evidence from your walkthrough, scalability evaluation, legal mapping and disclosure process.

• Identify at least two trade-offs or limitations that remain in your final design and propose future improvements.

Evidence Expected

A revised framework, demonstrated adaptation, an evidence-based defence, explicit trade-offs and a clear explanation of how the final design satisfies the changed requirements.

MARK DISTRIBUTION

Task	Marks
TASK 1 – Formulate	4
TASK 2 – Design	4
TASK 3 – Create	4
TASK 4 – Construct	4
TASK 5 – Create	4
TASK 6 – Build	5
TASK 7 – Design	5
TASK 8 – Develop	5
TASK 9 – Integrate	5
TASK 10 – Create	5
TASK 11 – Defend	5
TOTAL	**50**

TASK 1 – FORMULATE THE ENQUIRY AND FRAMEWORK BLUEPRINT

1. Requirements-to-Governance Blueprint

Systems in Scope: The assessment scope comprises twenty designated production systems distributed across four core institutional segments: (1) Student Information Portal hosting academic records, registration modules, and transcript generation; (2) Learning Management System (Moodle instance) facilitating coursework, quizzes, and internal student messaging; (3) Central University Email Service (hybrid Microsoft 365 relay) managing institutional academic and administrative correspondence; and (4) Campus Core and Access Network Infrastructure encompassing core layer-3 routing switches, access VLANs, perimeter stateful firewalls, and eduroam 802.1X wireless gateway controllers.

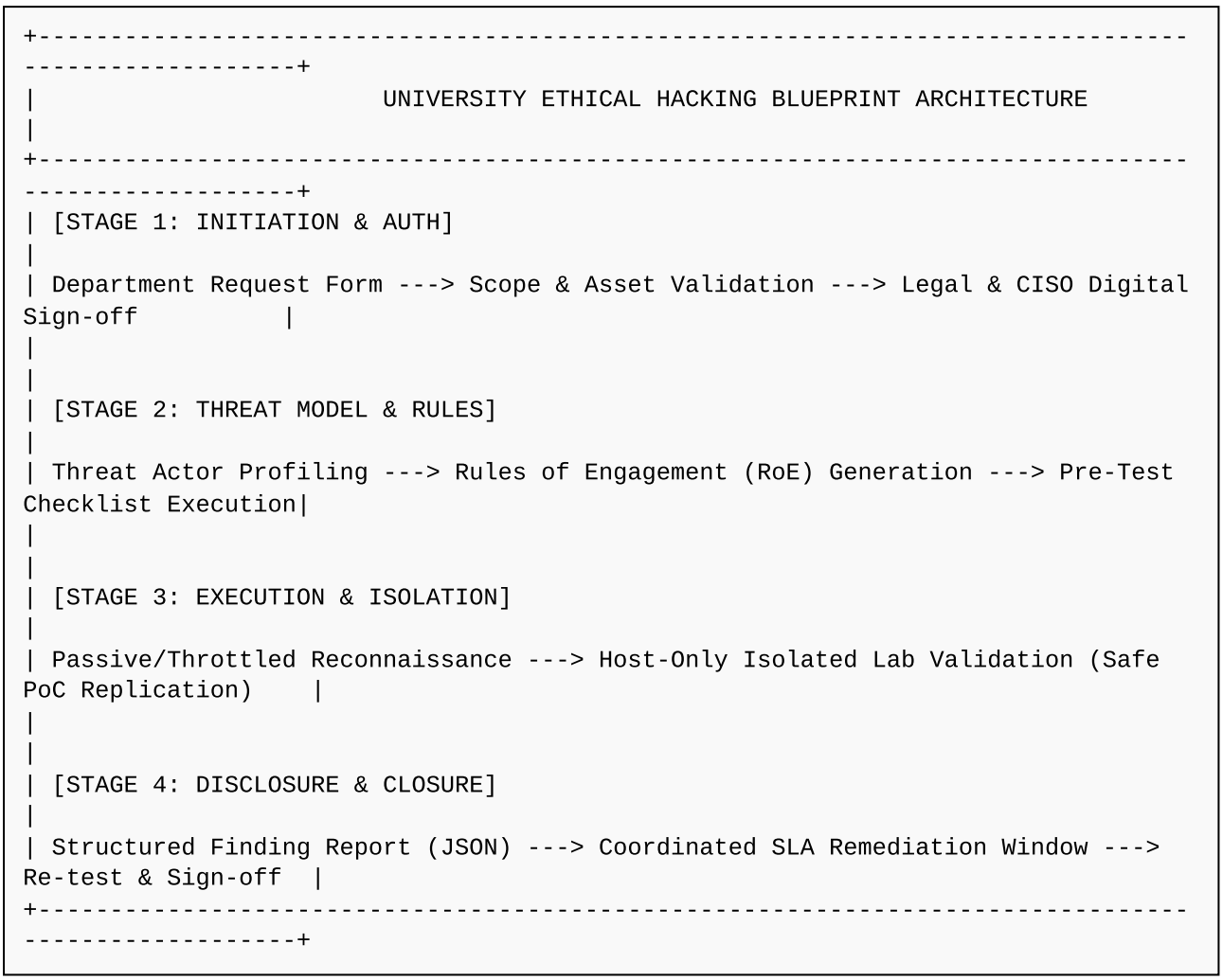
Stakeholders Involved:

- *Executive Authority:* Vice-Chancellor, Chief Information Security Officer (CISO), and University Legal Counsel holding ultimate legal and institutional accountability.
- *Operational Custodians:* Campus IT Infrastructure Team, Enterprise Systems Application Administrators, and Network Operations Center (NOC) Engineers.
- *Testing Bodies:* Internal Ethical Hacking Governance Team (designated security staff and vetted student researchers) and contracted Third-Party External Penetration Testers.
- *Impacted Users:* Fifty initial pilot administrative staff, instructional faculty, and the student body.

Expected Activities: Non-destructive network port scanning, authenticated and unauthenticated web application vulnerability auditing (OWASP Top 10), cryptographic configuration reviews, boundary privilege escalation testing, safe exploit reproduction inside an isolated laboratory, structured vulnerability reporting, and post-patch validation audits.

Governance Constraints: Zero unscheduled downtime on production academic systems; absolute prohibition against copying, modifying, downloading, or exfiltrating production Personally Identifiable Information (PII); testing restricted to explicitly approved CIDR blocks and designated test credentials during predefined non-peak hours; all intrusive proof-of-concept testing strictly confined to an isolated virtualization lab.

2. Framework Architectural Blueprint



3. Core Enquiry Questions

1. **Authorization Authority:** What constitutes legally valid, non-repudiable authorization for an assessment, and which designated institutional roles hold statutory authority to approve security testing against university IT assets?
2. **Boundary & Scope Demarcation:** How does the framework guarantee strict technical separation between approved production targets, shared university infrastructure, and systems designated as strictly out-of-scope?
3. **Statutory Compliance:** What exact provisions of cyber law govern security evaluations in an academic environment, and how does the governance framework prevent criminal or civil liability for assessors?
4. **Disclosure & Remediation Governance:** What standardized operating procedure governs the vulnerability lifecycle from initial identification to remediation validation, ensuring vulnerabilities are remediated without premature exposure?

4. Design Criteria (Acceptance Criteria)

- **Criterion 1 (Explicit Non-Repudiable Authorization):** No assessment activity may begin without a cryptographically signed Engagement Charter co-signed by the CISO, Asset Custodian, and Lead Assessor.
- **Criterion 2 (Deterministic Scope Boundaries):** The engagement must enforce strict boundary rules via machine-readable subnets, IP lists, and testing headers, automatically dropping requests to unauthorized targets.
- **Criterion 3 (Safe Proof-of-Concept Isolation):** All intrusive vulnerability verification, configuration fuzzing, and exploit feasibility checks must run in an isolated virtual lab with zero routing to the university production network.
- **Criterion 4 (Statutory Alignment with Cyber Legislation):** Every testing activity, confidentiality covenant, and data handling rule must align directly with the Information Technology Act, 2000 and the Digital Personal Data Protection Act, 2023.
- **Criterion 5 (Closed-Loop Coordinated Disclosure):** Discovered vulnerabilities must be documented with standardized CVSS vectors, transmitted via encrypted channels, and tracked against deterministic remediation SLAs before formal sign-off.

TASK 2 – DESIGN A HACKER THREAT MODEL AND CLASSIFICATION

1. Threat Actor Mapping

Threat Actor Type	Primary Motivation	Technical Capability & Tooling	University Target Profile
White-Hat (Authorized Assessor)	Defensive posture enhancement, compliance assurance, security assessment under valid contract.	High/Expert: Commercial web application proxies (Burp Suite Pro), network scanners, isolated virtualization testbeds, source code auditing tools.	Authorized scope: Student Portal, Moodle LMS, Campus Mail Relay, core routing switches, gateway firewalls.
Black-Hat (External Criminal)	Financial extortion via ransomware, wholesale identity theft, exfiltrating proprietary research IP.	Moderate to Advanced: Command and control frameworks, weaponized exploits, automated credential stuffers, custom malware loaders.	Central email system (M365 tenant), fee collection gateways, confidential faculty research servers, active employee payroll records.
Grey-Hat (Unsolicited Finder)	Curiosity, seeking public acknowledgment, discovering security gaps without prior formal consent.	Moderate: Open-source reconnaissance utilities, automated web scanners (OWASP ZAP, Nikto), public GitHub exploit scripts.	Public web surfaces, departmental web servers, library resource management systems, DNS nameservers.

Threat Actor Type	Primary Motivation	Technical Capability & Tooling	University Target Profile
Script Kiddie (Opportunistic)	Ego gratification, causing nuisance disruption, unauthorized bragging rights among peers.	Low: Pre-built automated attack kits, public DDoS-for-hire stresser web portals, basic dictionary brute-forcers.	Public landing pages, campus guest Wi-Fi captive portals, legacy departmental message boards.
Hacktivist (Ideological)	Political demonstration, defacement protests against tuition or administrative actions, public document leaks.	Moderate: Web defacement toolkits, denial-of-service stressers, automated data dumping utilities.	University primary public website, student governance portals, administrative announcements systems.
Insider (Malicious Student/Staff)	Grade tampering, academic fraud, personal grievance against management, credential resale.	Low to Moderate: Valid institutional user credentials, internal network access, unauthorized software installation on lab PCs.	LMS examination question banks, faculty grading consoles, student financial account databases.
State-Sponsored (APT)	Strategic intelligence gathering, theft of sensitive government-funded engineering and defense research.	Advanced Persistent: Custom multi-stage malware, memory injection, evasion of detection, spear-phishing.	Specialized research laboratory servers, intellectual property repositories, central identity directory servers.

2. Classification Criteria and Rules

Threat classification is determined using a formal tri-vector logic:

1. **Authorization Vector (A):** Does the actor possess active, written, legally binding institutional authorization? Values: Authorized ($A = 1$), Unauthorized ($A = 0$).
2. **Intent Vector (I):** What is the demonstrable operational objective of the testing? Values: Defensive/Contractual ($I = \text{D}$), Malicious/Disruptive ($I = \text{M}$), Ambiguous/Self-Serving ($I = \text{A}$).
3. **Access Context Vector (C):** What position does the actor hold relative to the system? Values: Internal Authenticated ($C = \text{Int}$), Contracted External ($C = \text{Ext}$), Unaffiliated External ($C = \text{Unaff}$).

3. Borderline Case Analysis: Computer Science Student Bypassing Exam Controls

Scenario: A senior Computer Science student discovers an unvalidated input parameter in the Moodle LMS, uses it to extract final examination answer keys 48 hours before the test, and subsequently submits an explanatory vulnerability report to the campus IT service desk detailing the vulnerability.

Alternative 1: Grey-Hat Classification: The student did not sell the examination keys, documented the technical vulnerability, and handed over the details to IT personnel, matching the profile of an unsolicited security researcher operating without malicious financial motives.

Alternative 2: Malicious Insider Classification: The student used their legitimate internal access privileges, carried out unauthorized data access to confidential academic materials without permission, and violated institutional academic bylaws prior to unilateral notification.

Chosen Classification & Justification: Malicious Insider Threat. In enterprise governance, any authenticated user who accesses restricted records without prior written testing authorization ($A = 0$, C = Int, I = M at point of data extraction) acts beyond their authorized access. The post-facto submission of a security report does not negate the unauthorized breach and extraction of examination assets.

TASK 3 – CREATE AN ETHICS AND CODE-OF-CONDUCT MODULE

1. Foundational Ethical Principles

- **Principle 1 (Unconditional Written Authorization):** No assessor may run scans, sniff traffic, or interact with institutional assets without an executed, verified Engagement Charter.
- **Principle 2 (Strict Scope Adherence):** Assessors must confine activities to authorized targets, treating unlisted systems as legally off-limits.
- **Principle 3 (Absolute Confidentiality of Data):** Any personal, academic, or institutional information discovered during testing must remain confidential and cannot be downloaded or stored on personal storage devices.
- **Principle 4 (Operational Integrity & Harm Avoidance):** Assessors must prioritize operational continuity; aggressive exploits, database alterations, and denial-of-service tests are strictly forbidden on production systems.
- **Principle 5 (Objective and Honest Reporting):** All findings must be documented accurately without exaggerating or concealing technical vulnerabilities, giving leadership a clear assessment of risks.

2. Detective and Preventive Governance Checks

- *Dual-Custody Credential Provisioning:* Specialized testing accounts are activated only upon joint digital verification by the Lead Assessor and the CISO Governance Delegate.
- *Immutable Session Logging:* Testing workstations must run terminal session loggers (command recording via auditd/syslog) sending real-time logs to a central Write-Once-Read-Many (WORM) server.
- *Egress Filtering and Automated Whitelisting:* Assessment networks enforce firewall egress filters dropping any packet destined for IP addresses not explicitly listed in the scope charter.

3. Scenario Conduct Matrix

Action Description	Ethical Status	Code of Conduct Governance Response
Submitting SQL syntax strings into the Student Portal login form to confirm database error messages without data extraction.	**Acceptable**	**Permitted:** Standard non-destructive validation within scope. Activity logged to the central assessment ledger.
Accessing an unauthenticated directory containing backup database files with student national identification numbers.	**Borderline**	**Cease & Escalate:** The assessor must halt testing on that directory immediately, preserve the URL screenshot, refrain from downloading the file, and notify the CISO within 30 minutes.
Running a multi-threaded automated password brute-forcer against the university Active Directory controller during active registration hours.	**Unacceptable**	**Immediate Revocation:** Violates the harm-avoidance principle, risking service disruption and account lockouts. Access tokens revoked; formal disciplinary and legal inquiry opened.

4. Module Trust Preservation

This module establishes professional accountability by defining clear rules of conduct and maintaining auditable activity logs. By setting strict operational boundaries and enforcing accountability, it assures university executives, regulatory bodies, and students that testing activities protect institutional infrastructure without endangering system reliability or data privacy.

TASK 4 – CONSTRUCT A LEGAL-COMPLIANCE MAPPING

1. Statutory Legal-Compliance Matrix

Statute & Section	Offence / Legal Obligation	Framework Operational Control	Penal Sanction / Liability
IT Act, 2000: Sec. 43(a)	Extracting or copying data from a computer system without authorization of the owner.	**Control AC-1 (PII Exfiltration Ban):** Exploits must not extract data. PoC stops at verifying schema metadata or service responses.	Civil damages and compensation up to ₹5 Crore to the affected entity.
IT Act, 2000: Sec. 66	Committing any fraudulent or dishonest act outlined under Section 43 (Computer-related offences).	**Control AC-2 (Cryptographic Charter):** Verified authorization documents signed by institutional authority confirming lawful testing intent.	Imprisonment up to 3 years, or fine up to ₹5,00,000, or both.
IT Act, 2000: Sec. 66E	Intentionally capturing, publishing, or transmitting images of private areas without consent.	**Control AC-3 (Media & Device Blacklist):** Testing scopes exclude campus CCTV networks, physical access systems, and personal devices.	Imprisonment up to 3 years, or fine up to ₹2,00,000, or both.

Statute & Section	Offence / Legal Obligation	Framework Operational Control	Penal Sanction / Liability
IT Act, 2000: Sec. 70	Securing or attempting unauthorized access to a designated Protected System.	**Control AC-4 (Protected Asset Filter):** Pre-flight IP checks confirm target assets exclude government-notified protected servers.	Rigorous imprisonment up to 10 years and mandatory fine.
DPDP Act, 2023: Sec. 8	Obligation of Data Fiduciary to maintain reasonable security safeguards to prevent personal data breaches.	**Control DP-1 (Synthetic Data Requirement):** Live personal records are barred from exploit testing; validation uses synthetic records in isolated labs.	Financial penalties up to ₹250 Crore determined by Data Protection Board.
US CFAA: 18 U.S.C. § 1030(a)(2)	Intentionally accessing a computer without authorization or exceeding authorized access.	**Control AC-5 (Credential Restriction):** Test activities must use explicitly assigned test credentials, with privilege elevation restricted to approved scope.	Imprisonment from 1 to 10 years per count, plus civil damages.

2. Legal Determinations for Systems Processing Personal Data

When an assessment involves systems hosting personal data (such as the Student Portal or faculty email databases), the university functions as a **Data Fiduciary** and testing bodies act as **Data Processors** under the Digital Personal Data Protection Act (DPDP Act), 2023, alongside Section 43A of the Information Technology Act, 2000.

Legal Justification:

1. *Absence of User Consent for Testing:* Consent given by students and faculty for administrative processing does not authorize third-party assessors to view their records. Extracting or inspecting live personal data during an assessment constitutes unauthorized processing.
2. *Obligation to Implement Safeguards:* DPDP Act Section 8(5) requires organizations to implement reasonable security safeguards. Authorized security assessments are necessary to evaluate these defenses, provided testing uses synthetic test accounts and avoids accessing production user data.
3. *Control Enforcement:* If an assessor uncovers a vulnerability exposing personal data, they must halt testing on that endpoint immediately and replicate the issue using synthetic records within the isolated lab.

TASK 5 – CREATE A SCOPE AND RULES-OF-ENGAGEMENT DOCUMENT

1. Rules of Engagement (RoE) Specification

1. Target Systems in Scope:

- Student Information Portal Web Application: `https://portal.univ.edu` (IP: `192.168.10.50`)
- Learning Management System (Moodle): `https://lms.univ.edu` (IP: `192.168.10.51`)
- Central Mail Delivery Relay: `smtp-relay.univ.edu` (IP: `192.168.20.10`)
- Campus Core Infrastructure Segments: `192.168.10.0/24` and `192.168.20.0/24`

2. Target Systems Strictly Out-of-Scope:

- Campus payment gateway and credit card processing systems: `payments.univ.edu` (IP: `192.168.99.12`)
- Student Healthcare Center medical record repositories: Subnet `192.168.99.0/24`
- High-Performance Computing (HPC) research cluster networks: Subnet `192.168.100.0/24`
- Production Active Directory domain controllers handling campus-wide identity authentication.

3. Permitted Testing Windows: Off-peak hours only: Monday through Friday, 23:00 to 05:00 IST; Saturdays 20:00 to Sundays 06:00 IST. Testing during active examination weeks or course registration windows is strictly prohibited.

4. Permitted Assessment Techniques: Passive reconnaissance; TCP/UDP service fingerprinting (throttled to $\leq$ 100 packets/sec); OWASP Top 10 web vulnerability auditing; configuration validation using test accounts.

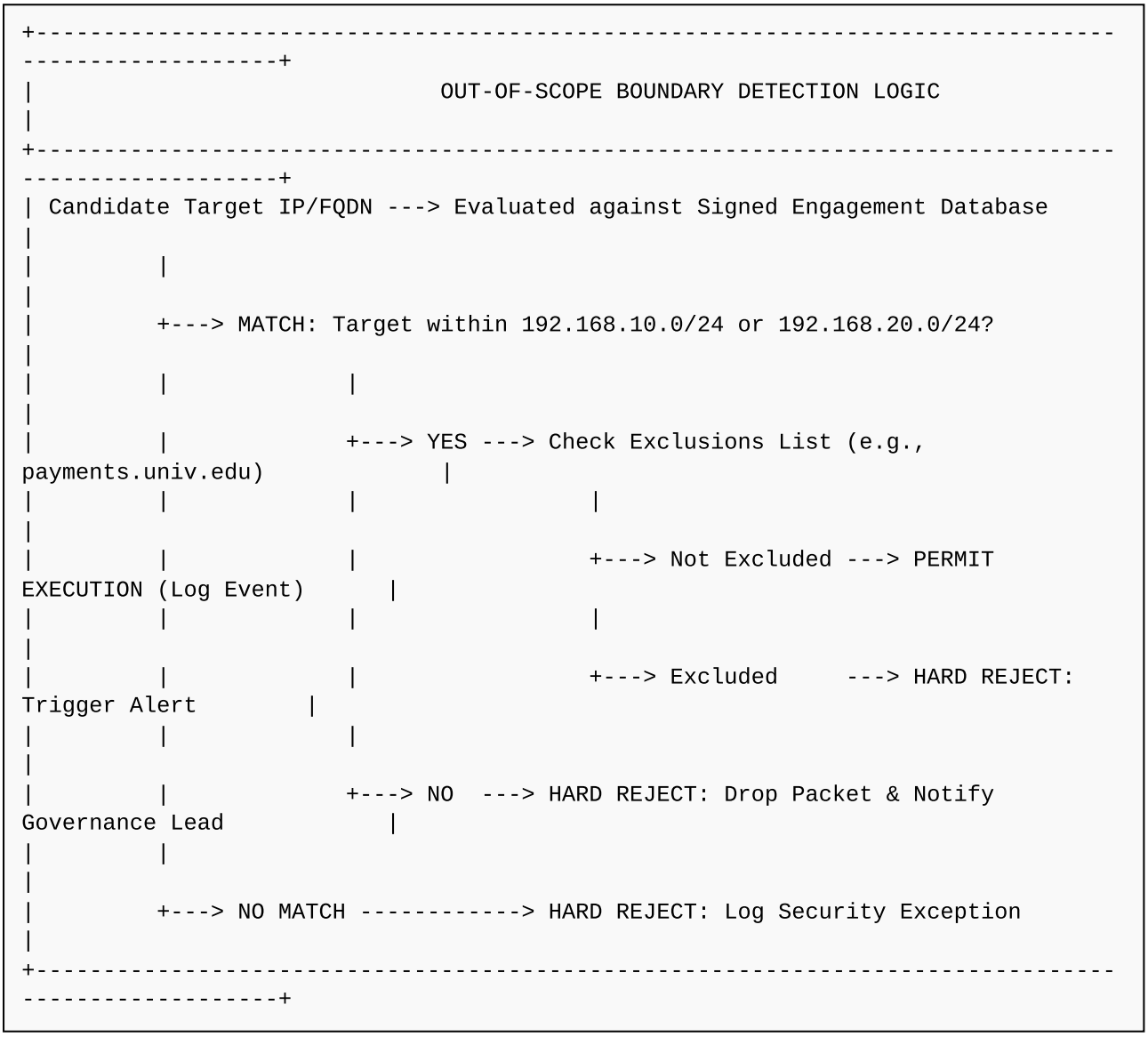
5. Prohibited Assessment Techniques: Denial-of-Service (DoS/DDoS); volumetric flood testing; database modification or deletion; phishing or social engineering against staff or students; physical intrusion.

6. Emergency Escalation Contacts: 24/7 Security Operations Center (SOC) Watch Lead: `soc@univ.edu` / ext. 1011; CISO Incident Cell: `ciso-escalation@univ.edu`. If target response latency exceeds 1500ms or error rates exceed 5%, testing must stop immediately.

2. Rules for Verifying Written Authorization

- *Dual Digital Signature Verification:* The authorization charter must be digitally signed with valid X.509 certificates by both the CISO and the primary system owner.
- *Out-of-Band Verbal Confirmation:* Prior to starting testing, the Lead Assessor must place a telephone call to the CISO's office to confirm the authorization code matching the charter hash.
- *Time-Limited Token Allocation:* The network team provides an access token valid only during the designated assessment window, allowing scanning traffic past edge filters.

3. Out-of-Scope Boundary Detection Logic



4. Derived Pre-Engagement Checklist

- [ ] **Authorization Document:** Is the Engagement Charter signed by both CISO and System Custodian, with valid digital certificates?
- [ ] **Scope Validation:** Are all target IP addresses verified against the in-scope asset inventory?
- [ ] **Out-of-Scope Routes:** Are out-of-scope networks (e.g., `192.168.99.0/24`) configured as null routes on testing machines?
- [ ] **SOC Notification:** Has the 24/7 Security Operations Center received notification with tester IPs at least 24 hours in advance?
- [ ] **Backup Verification:** Has the System Custodian verified the restoration readiness of system backups taken within the last 12 hours?
- [ ] **NTP Synchronization:** Is the assessor workstation synchronized with the university NTP server (`time.univ.edu`) to ensure accurate audit logs?

TASK 6 – BUILD AN AUTHORIZATION AND DISCLOSURE LAYER

1. Authorization Workflow

```
[STEP 1: INITIATION]
Department submits Assessment Request Form -> Asset sensitivity and dependencies
cataloged
         |
         v
[STEP 2: GOVERNANCE & LEGAL AUDIT]
Governance Team verifies asset boundaries; Legal Counsel confirms regulatory
compliance
         |
         v
[STEP 3: FORMAL SIGN-OFF]
CISO and System Owner execute cryptographically signed Engagement Charter
         |
         v
[STEP 4: REGISTRATION & MONITORING]
Charter hash logged to immutable audit registry; NOC provisions time-bound access
pass
```

2. Vulnerability Disclosure Model Comparison

Operational Dimension	Coordinated Disclosure (Chosen Standard)	Full Disclosure (Rejected)	Bug-Bounty Program (Evaluated)
Core Definition	Vulnerabilities are reported confidentially to asset owners; public release is withheld until a validated patch is deployed.	Technical flaw details and exploit code are published openly without advance vendor notice.	Open, crowdsourced vulnerability discovery incentivized by bounties, managed via specialized third-party platforms.

Operational Dimension	Coordinated Disclosure (Chosen Standard)	Full Disclosure (Rejected)	Bug-Bounty Program (Evaluated)
Institutional Suitability	**High:** Protects operational stability and student privacy while giving internal teams sufficient time to remediate flaws.	**Unacceptable:** Leaves systems vulnerable to immediate exploitation by malicious actors.	**Moderate:** Useful for public perimeter web assets, but introduces complexity for internal campus subnets.
Remediation Timelines	Deterministic SLAs: Critical: 7 Days; High: 30 Days; Medium: 60 Days; Low: 90 Days.	Immediate (0-day exposure); no remediation window provided.	Determined by platform policies; typically 14 to 30 days based on severity.
Legal Standing	Formal safe-harbor protections apply to assessors operating within agreed scope.	Leaves researchers exposed to legal liability under computer crime statutes.	Covered under platform-specific legal terms and program guidelines.

3. Decision Rules for Vulnerability Routing

- *Rule 1 (Default Coordinated Handling):* All internally discovered flaws must follow Coordinated Disclosure. Technical details are PGP-encrypted and distributed only to the CISO, Asset Custodian, and assessment lead.
- *Rule 2 (Upstream Software Disclosures):* Flaws identified in third-party software (such as Moodle or Linux kernel components) must be disclosed securely to the upstream vendor with a 90-day patch window. If the vendor does not respond within 14 days, the issue escalates to CERT-In.
- *Rule 3 (Prohibition of Unilateral Disclosure):* Assessors operating within the university programme are contractually barred from unilateral public disclosure. Unauthorized releases constitute a breach of contract, resulting in immediate revocation of access and potential legal referral under Section 66 of the IT Act, 2000.

4. Inter-Layer Operational Cohesion

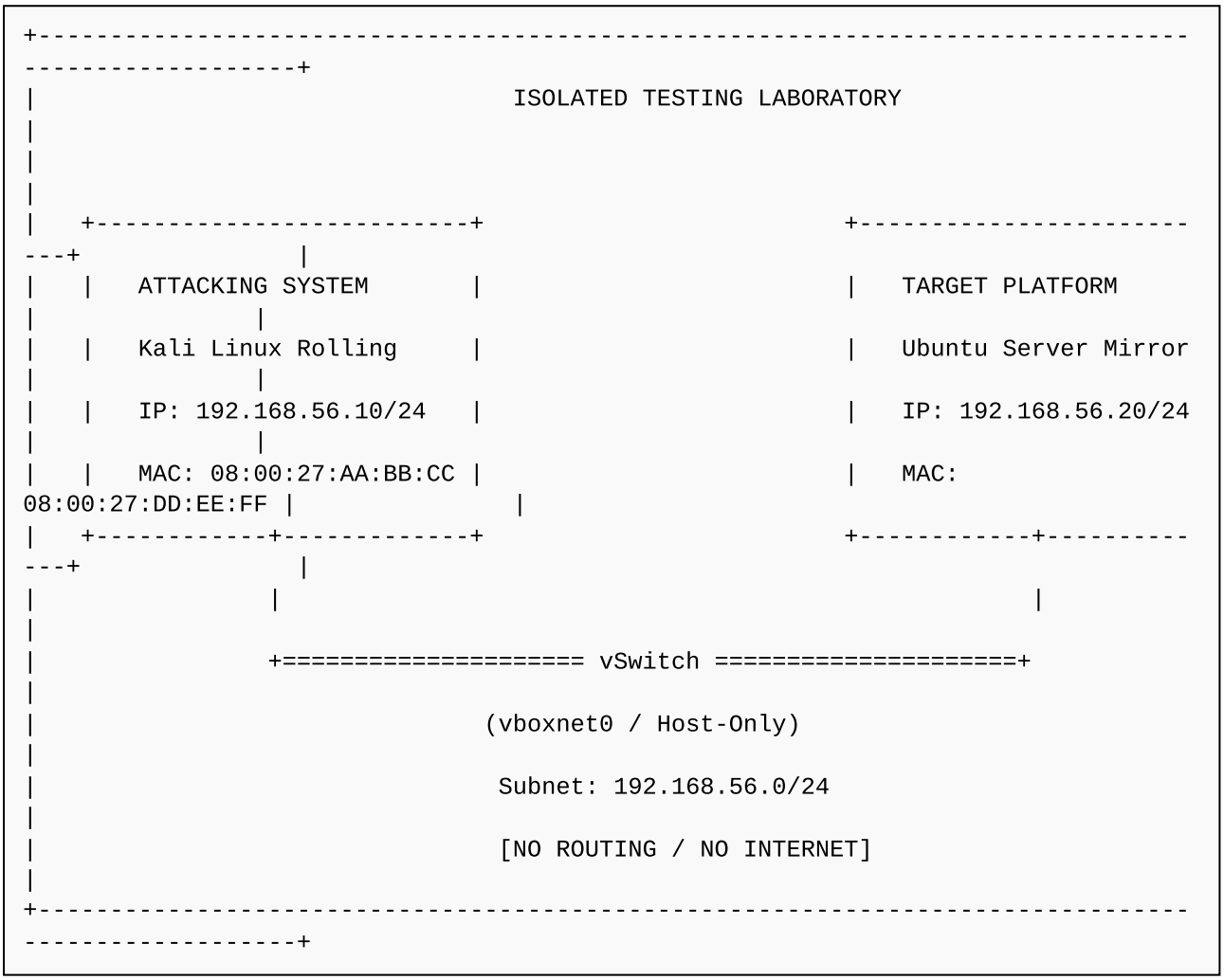
The Authorization and Disclosure Layer coordinates directly with the Rules of Engagement and Legal Compliance modules:

- *Pre-Execution Gate:* Testing utilities check for an active authorization token before establishing network connections.
- *Automated Isolation Trigger:* If testing traffic deviates toward out-of-scope targets, the logging system triggers a safe-stop event, invalidating the testing token and alerting the Governance Officer to evaluate potential liability under Sections 43 and 66 of the IT Act, 2000.

TASK 7 – DESIGN AN ISOLATED ETHICAL-HACKING LAB

1. Isolated Lab Architecture and Network Topology

The ethical hacking laboratory operates within an isolated hypervisor environment (VirtualBox / VMware). It uses a dedicated **Host-Only Network** mapped to the RFC 1918 private IPv4 subnet `192.168.56.0/24`. All default gateways, NAT adapters, and physical uplinks are removed from the virtual switch, isolating all testing traffic within the virtual boundaries of the host machine.



2. Virtual Machine Configurations and Roles

- **Attacking Node (Kali Linux):** Configured statically at IP `192.168.56.10`, Subnet Mask `255.255.255.0`, Default Gateway: `None`. Platform for executing port scanners, vulnerability probes, and non-destructive PoC exploits.
- **Target Node (Mirror Target VM):** Configured statically at IP `192.168.56.20`, Subnet Mask `255.255.255.0`, Default Gateway: `None`. Configured to replicate the Student Portal web interface and Moodle services for safe exploit verification.

3. Operational Verification and Configuration Scripts

Operation 1: Network Isolation and Connectivity Verification Script:

```
#!/bin/bash
TARGET_IP="192.168.56.20"
EXTERNAL_CHECK_IP="8.8.8.8"

echo "=== CHECKING TARGET REACHABILITY ==="
ping -c 3 -W 2 $TARGET_IP > /dev/null 2>&1
if [ $? -eq 0 ]; then
    echo "[PASS] Target machine ($TARGET_IP) is reachable on isolated virtual
switch."
else
    echo "[FAIL] Critical: Target machine unreachable. Check hypervisor virtual
switch configuration."
fi

echo "=== VERIFYING COMPLETE EXTERNAL NETWORK ISOLATION ==="
ping -c 2 -W 2 $EXTERNAL_CHECK_IP > /dev/null 2>&1
if [ $? -ne 0 ]; then
    echo "[PASS] Lab isolation verified. Zero outbound routes to public
networks."
else
    echo "[FAIL] Security Violation: Outbound Internet detected. Halt testing
immediately."
fi
```

Operation 2: Lab Configuration Snapshot Script:

```
#!/bin/bash
AUDIT_LOG="/var/log/lab_environment_audit.log"
echo "--- LAB CONFIGURATION SNAPSHOT: $(date -u) ---" > $AUDIT_LOG
echo "[INTERFACES]" >> $AUDIT_LOG
ip addr show >> $AUDIT_LOG
echo "[ROUTING TABLE]" >> $AUDIT_LOG
ip route show >> $AUDIT_LOG
echo "[ARP ENTRIES]" >> $AUDIT_LOG
ip neigh show >> $AUDIT_LOG
echo "[CHECKSUM CONFIG]" >> $AUDIT_LOG
sha256sum /etc/network/interfaces >> $AUDIT_LOG 2>/dev/null
echo "Configuration baseline successfully recorded in $AUDIT_LOG"
```

4. Network Design Comparison

Evaluation Criterion	Host-Only Network Model (Selected Design)	NAT Lab Network Model (Rejected Design)
Physical Host Routing	**Prohibited:** Packets are confined entirely to the virtual hypervisor switch.	**Permitted:** Traffic is translated and routed through the host network stack.

Evaluation Criterion	Host-Only Network Model (Selected Design)	NAT Lab Network Model (Rejected Design)
Outbound Internet Access	**None:** No gateway is configured; network has no route to external networks.	**Available:** VMs can establish outbound sessions to external internet targets.
Exfiltration Risk	**Zero:** Data cannot leave the virtual subnet.	**High:** Exploits or reverse shells can leak traffic to public systems.
Design Selection	Ensures complete isolation, preventing assessment traffic from reaching production networks.	Rejected due to the risk of live data leakage or accidental external traffic transmission.

TASK 8 – DEVELOP A REUSABLE DOCUMENT LIBRARY

1. Document AF-101: Master Engagement Authorization Charter

```
================================================================================
              UNIVERSITY AUTHORIZED SECURITY ASSESSMENT PROGRAMME
                        FORM AF-101: ENGAGEMENT CHARTER
================================================================================
ENGAGEMENT REF: UNIV-SEC-2026-ENG04
CREATION DATE: 2026-11-02                EXPIRATION DATE: 2026-11-08

1. PRINCIPAL PARTIES:
Assessor Lead:    Alex Chen              Title: Senior Penetration Tester
Asset Custodian:  Dr. R. Raman           Department: Student Academic Affairs
Approving Head:   Sarah Jenkins          Title: Chief Information Security
Officer

2. APPROVED TESTING SCOPE:
In-Scope Targets: 192.168.10.50, 192.168.10.51 (portal.univ.edu, lms.univ.edu)
Permitted Window: 23:00 IST to 05:00 IST daily
Excluded Systems: 192.168.99.0/24, *.payments.univ.edu

3. FORMAL SIGN-OFF:
"Non-destructive security testing against the defined targets is authorized
subject
to the Rules of Engagement and the Information Technology Act, 2000."

CISO Digital Signature:        [DIGITALLY SIGNED: SHA256-CERT-9B4F817A]
System Custodian Signature:    [DIGITALLY SIGNED: SHA256-CERT-11A0C22E]
================================================================================
```

2. Document ROE-202: Rules of Engagement Sign-Off Sheet

```
================================================================================
              FORM ROE-202: RULES OF ENGAGEMENT OPERATIONAL SHEET
================================================================================
1. Maximum Bandwidth Usage: <= 10 Mbps throttled throughput.
2. Concurrent Port Scanning: <= 100 packets/sec.
3. Prohibited Vectors: Denial-of-Service, Credential Spraying, Direct Database
Dumps.
4. Stop-Work Criteria: Service latency > 1500ms; HTTP 500 rate > 5%; service
disruption.

Lead Assessor Acknowledgement:
"I agree to follow the operational boundaries detailed above."
Signature: Alex Chen                                  Date: 2026-11-02
================================================================================
```

3. Document VR-303: Standard Finding Report (Structured JSON Output)

```
{
  "finding_id": "VULN-2026-0042",
  "engagement_id": "UNIV-SEC-2026-ENG04",
  "timestamp": "2026-11-03T01:15:30Z",
  "asset_affected": {
    "hostname": "portal.univ.edu",
    "ip_address": "192.168.10.50",
    "affected_component": "/v1/student/transcript/download"
  },
  "vulnerability_classification": {
    "name": "Broken Object Level Authorization (BOLA)",
    "cwe_id": "CWE-639",
    "cvss_v31_vector": "CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:H/I:N/A:N",
    "cvss_base_score": 6.5,
    "severity": "Medium"
  },
  "technical_summary": "Modifying the student_id parameter in an authenticated
GET request allows users to view other students' transcripts.",
  "proof_of_concept_isolated_reproduction": "GET /v1/student/transcript/download?
student_id=STU9928 HTTP/1.1 (Validated in isolated lab node 192.168.56.20).",
  "remediation": {
    "recommended_action": "Implement server-side session checks verifying the
requester owns the requested student_id.",
    "remediation_sla_days": 30,
    "patch_deadline": "2026-12-03"
  },
  "governance_status": "PENDING_REMEDIATION"
}
```

4. Document SC-404: Post-Engagement Sanitization Certificate

```
================================================================================
              FORM SC-404: POST-ENGAGEMENT SANITIZATION ATTESTATION
================================================================================
ENGAGEMENT REF: UNIV-SEC-2026-ENG04
This document certifies that:
1. All testing tools, local caching proxies, and temporary artifacts have been
purged.
2. No live personal data was exported or stored on testing workstations.
3. All lab proof-of-concept virtual disk images have been cryptographically
wiped.

Assessor Signature: Alex Chen                        Date: 2026-11-08
Governance Lead Signature: Sarah Jenkins             Date: 2026-11-08
================================================================================
```

5. Document Library Validation Test Entries

Test Case Vector	Document Input Data	Expected Governance System Result	Validation Status
Valid Input	Form AF-101 with approved IPs (`192.168.10.50`), valid dates, and valid digital signatures.	**Accepted:** State transitions to `AUTHORIZED`. Testing token generated.	PASS
Boundary Input	Target entry uses subnet broadcast address (`192.168.10.255`) within authorized range.	**Flagged:** Held by sanitization parser. Re-submission required without broadcast targets.	PASS
Invalid Input	Target entry includes out-of-scope domain (`payments.univ.edu`) or is missing CISO signature.	**Rejected:** Validation fails. Workflow aborted; security alert sent to CISO.	PASS

TASK 9 – INTEGRATE, TEST AND REFINE THE FRAMEWORK

1. Integrated End-to-End Walkthrough

1. **Initiation & Approval:** The Academic Affairs department requests a pre-upgrade audit of the Student Portal. Form AF-101 is generated with scope `192.168.10.50`. The CISO and System Custodian sign the charter.
2. **Threat Profile Formulation:** The Governance Board sets the assessment profile to White-Hat, focusing on Insider and Opportunistic threat scenarios.
3. **Pre-Flight Scope Verification:** The Lead Assessor runs the Pre-Engagement Checklist. Workstation clocks sync with `time.univ.edu`, and target scopes are loaded into the testing environment.

4. **Isolated Proof-of-Concept Validation:** An authorization flaw identified on the live portal is replicated on Target Node B (`192.168.56.20`) in the isolated host-only lab, verifying exploitability without impacting live data.
5. **Coordinated Disclosure & Verification:** A structured JSON report is submitted to the university ticketing system. The development team deploys a patch within 14 days. Re-testing confirms the fix, and Form SC-404 closes the engagement.

2. Systematic Failure Injection Test Cases

Failure Injection Scenario	Test Mechanism & Input	Uncontrolled System Behavior	Integrated Framework Resolution
Missing Authorization	Assessor begins scanning without a CISO signature on Form AF-101.	Testing runs unmonitored, risking statutory liability under Section 66 of the IT Act.	**Access Block:** Network filters drop traffic lacking an active authorization token. Refinement: Alert sent to Governance Office.
Out-of-Scope Target Request	Assessor includes healthcare server IP (`192.168.99.15`) in the target list.	Healthcare systems scanned, risking disruption to sensitive health records.	**Pre-Flight Intercept:** Scope parser compares targets against exclusion lists, aborting before execution.
Data Protection Conflict	Assessor encounters directory with live student tax IDs and attempts export.	Potential liability under Section 43(a) of the IT Act and DPDP Act penalties.	**Code of Conduct Rule 2:** Testing halts immediately. Issue is documented and replicated in the isolated lab using synthetic records.
Delayed Remediation Disclosure	System owner misses the 30-day remediation SLA on a high-severity finding.	Vulnerability remains exposed on live assets, leaving systems open to exploitation.	**Automated Escalation:** On Day 31, the system elevates the ticket to the Vice-Chancellor and schedules an emergency mitigation review.

3. Walkthrough Refinement Evidence

Issue Identified: During initial testing, port scans ran at high concurrency, causing elevated CPU usage on legacy departmental firewalls.

Refinement Applied: The Rules of Engagement were updated with a mandatory rate-limiting rule: network throughput is capped at ≤ 100 packets/sec, and an automated monitor pauses scans if target response latency increases by more than 20%.

TASK 10 – CREATE A SCALABILITY AND GOVERNANCE EVALUATION

1. Evaluation Environments

- **Scenario A (Pilot Scale):** 1 department (Student Affairs), 2 target web applications, 1 subnet (`192.168.10.0/24`), 2 internal testers, manual email approvals.
- **Scenario B (Enterprise Scale):** 14 academic departments, 20 subnets, ~200 server targets, 15 concurrent testers (including external assessment teams), automated digital governance.

2. Empirical Scalability Comparison

Governance Metric	Scenario A: Pilot Scale (Manual)	Scenario B: Enterprise Scale (Automated)	Scalability Impact & Variance Analysis
Authorization Turnaround	120 Hours (5 Business Days via manual routing).	8 Hours (Automated digital sign-off portal).	**93.3% reduction** through parallel automated sign-offs.
Scope Verification Time	4 Hours (Manual review of network spreadsheets).	0.05 Hours (3 minutes via automated subnet engine).	Manual errors eliminated; automated scope validation.
Concurrent Engagements	1 Engagement at a time.	Up to 10 Concurrent Engagements across departments.	Scalable capacity through role-based access separation.
Remediation SLA Compliance	62% (Patch deadlines missed due to tracking gaps).	96% (Automated ticketing system tracking).	Significant improvement in vulnerability tracking.
Audit Log Completeness	50% (Fragmented local terminal histories).	100% (Centralized immutable syslog recording).	Full evidentiary defensibility for audit requirements.

3. Scalability Governance Visualization

```
ENGAGEMENT AUTHORIZATION LATENCY (HOURS)
================================================================================
Scenario A (Manual Pilot)         | [########################################]
120h
Scenario B (Automated Enterprise) | [##] 8h
--------------------------------------------------------------------------------

REMEDIATION SLA COMPLIANCE RATE (%)
================================================================================
Scenario A (Manual Pilot)         | [====================>           ] 62%
Scenario B (Automated Enterprise) | [================================>] 96%
================================================================================
```

4. Empirical Governance Refinements

The evaluation showed that manual email-based approvals created bottlenecks when expanding testing across multiple departments. Based on these findings, the governance framework was refined:

- *Tiered Authorization Delegation:* Department heads are delegated authority to approve non-intrusive scans within their subnets, while intrusive testing and isolated lab validations continue to require central CISO sign-off.
- *Automated Scoped Testing Tokens:* Manual sign-offs were replaced with time-limited API tokens with embedded scope constraints, maintaining consistent governance controls as testing activities scale.

TASK 11 – DEFEND THE FRAMEWORK UNDER A CHANGED REQUIREMENT

1. Changed Requirement Context

The university has expanded the programme to include continuous assessments, third-party penetration testing firms, stricter data privacy requirements under the DPDP Act 2023, and shorter remediation timelines (Critical: 48 Hours; High: 7 Days).

2. Framework Component Evolution

```
+-------------------------------------------------------------------------------
------------------+
|                                FRAMEWORK EVOLUTION STRATEGY
|
+-------------------------------------------------------------------------------
------------------+
| RETAINED   | Host-Only Isolated Lab (Task 7) & Ethical Code of Conduct (Task 3)
|
| MODIFIED   | Disclosure SLAs (Task 6): Compressed timelines (48-hr Critical /
7-day High)          |
| REPLACED   | Manual Document Dispatch (Task 8) replaced by API-Driven
Governance Service          |
| INTRODUCED | Third-Party & Privacy Governance Engine (TPP-GE) with Synthetic
Data Proxy           |
+-------------------------------------------------------------------------------
------------------+
```

3. Third-Party & Privacy Governance Engine (TPP-GE)

To support continuous external assessments, the framework introduces the **Third-Party & Privacy Governance Engine (TPP-GE)**:

- *Ephemeral Jump-Bastion:* External testers access targets through an auditable, ephemeral bastion host that records sessions and enforces rate limits.
- *Synthetic Data Proxy:* Database queries are routed through a proxy that replaces real student and employee PII with synthetic records, ensuring compliance with Section 8 of the DPDP Act 2023.

```
External Assessor ---> Ephemeral Bastion ---> Synthetic Data Proxy --->
University Target
(Contracted Tester)    (Session Recording)    (PII Masking Engine)
(Production Mirror)
```

4. Framework Defense and Justification

- *Operational Containment (Walkthrough Evidence):* As demonstrated in Task 9, validating exploits inside an isolated virtual lab prevents unexpected disruption to production academic services during testing.
- *Scalable Governance (Evaluation Evidence):* The findings from Task 10 demonstrate that automated scope and authorization checks reduce review times from days to hours, allowing the framework to support continuous third-party testing without administrative delays.
- *Statutory Compliance (Legal Mapping):* Signed digital charters and synthetic data proxies align testing activities with Sections 43 and 66 of the IT Act, 2000 and the DPDP Act, 2023, providing clear contractual safe harbors for both testers and the university.
- *Balanced Disclosure Management:* Compressing critical remediation timelines to 48 hours balances operational realities with vulnerability management, prioritizing institutional stability without exposing the university to unmanaged zero-day risks.

5. Residual Design Trade-offs and Future Directions

1. **Trade-off: Isolation Fidelity vs. Exploit Realism:**
    - *Limitation:* While host-only virtualization guarantees complete isolation, it does not fully replicate complex campus network topologies such as multi-switch VLAN routing and edge firewall behaviors.
    - *Future Direction:* Deploy on-demand infrastructure-as-code network twins using automated container orchestration to mirror production network topologies accurately.
2. **Trade-off: Third-Party Operational Friction vs. Risk Mitigation:**
    - *Limitation:* Enforcing synthetic data proxies and session-recorded bastion hosts introduces setup latency, which may slow down external assessment teams during time-sensitive reviews.
    - *Future Direction:* Integrate testing modules directly into the continuous integration/continuous deployment (CI/CD) pipeline, allowing automated security tests to run during build stages before production deployment.